

Lecture 6

1. Firewall (جدار الحماية)

- A device or software designed to **block unauthorized traffic** between networks.
- It inspects all **incoming (Inbound)** and **outgoing (Outbound)** packets and decides whether to allow or block them.

Packet outcomes:

- **Accepted (مسموح):** Packet is allowed.
- **Denied (مرفوض بدون رسالة):** Packet blocked silently.
- **Rejected (مرفوض مع رسالة):** Packet blocked and an error is sent to the sender.

Types of Filtering

1. **Ingress Filtering (فلتر الدخول):** Inspects incoming traffic to protect the internal network.
2. **Egress Filtering (فلتر الخروج):** Inspects outgoing traffic to prevent access to certain sites/services.

Firewall Policies

- **Blacklist (القائمة السوداء) – Default-Allow:** Allow all except explicitly blocked packets.
- **Whitelist (القائمة البيضاء) – Default-Deny:** Block all except explicitly allowed packets.

2. Firewall Evolution (تطور الجدران النارية)

Generation	Era	Core Principle	Example
1st – Packet Filtering	1980s	Filter by IP, Port, Protocol	Cisco IOS ACLs
2nd – Stateful Inspection	1990s	Tracks session state	Check Point Firewall-1
3rd – Application/Proxy Firewall	2000s	Filter by application	Squid Proxy
Next-Gen (NGFW)	2008s+	Deep inspection, IDS/IPS, app awareness	Palo Alto, Fortinet

3. Types of Firewalls (أنواع الجدران النارية)

A. Packet-Filtering Firewalls

- Filter packets based on rules (IP, Port, Protocol).

- **Types:**

1. **Static:** Fixed rules, simple, best for small networks.
2. **Dynamic:** Adaptive rules based on traffic.
3. **Stateless:** Does not track connections, fast but limited security.
4. **Stateful:** Tracks active sessions, stronger security.

B. Stateful Inspection Firewalls (جدار حماية بحالة الجلسة)

- Maintains a **state table** of connections.
- Makes decisions based on **current session states and security rules**.
- Can detect multi-packet attacks.

C. Proxy / Application Firewalls (جدار حماية البروكسي / التطبيقات)

- Acts as an **intermediary** between internal clients and external servers.
- Inspects data at **Application Layer (Layer 7)**.
- Features: DPI (Deep Packet Inspection), Caching, Compression, Filtering.
- Types: Transparent, Reverse, Anonymous, Elite/High-Anonymity Proxy.

D. Web Application Firewall (WAF – جدار حماية تطبيقات الويب)

- Protects web apps by inspecting HTTP/HTTPS traffic.
- Detects attacks like **SQL Injection (حقن SQL)** and **XSS (Cross-Site Scripting)**.
- Can be network-based, host-based, or cloud-based.

E. Next-Generation Firewalls (NGFW – الجدار الناري المتقدم)

- Includes advanced features beyond stateful inspection:
 - Application awareness & control
 - Integrated IDS/IPS
 - Cloud threat intelligence
- Can inspect **encrypted traffic** and tie traffic to users.

F. Unified Threat Management (UTM – إدارة التهديدات الموحدة)

- All-in-one security device combining:
 - Firewall, IDS/IPS, Antivirus, Content/Spam filtering, VPN support
- Simplifies security management and improves efficiency.

Lecture 7

1 Network Firewalls

Types of Firewalls:

1. Screening Router

- Filters packets based on security policy.
- Positioned between **Internet/Untrusted Network** and **Internal/Trusted Network**.
- Can allow or block traffic.
- **Arabic:** يفلتر الحزم وفق سياسة الأمان ويمنع الوصول غير المصرح به.

2. Simple Firewall

- Uses a **firewall device** in addition to screening router.
- Provides extra security for web, SMTP, and internal servers.
- **Arabic:** يضيف حماية إضافية على الشبكة الداخلية والخوادم.

3. Multi-Legged Firewall

- Adds **DMZ (Demilitarized Zone)** – a semi-trusted network for public-facing servers like Web or SMTP.
- Helps isolate internal network from Internet threats.
- **Arabic:** تحمي الشبكة الداخلية من التهديدات الخارجية (DMZ) المنطقة العازلة.

Firewall Characteristics:

- **Service Control:** Which services can be accessed (inbound/outbound)
- **Direction Control:** Direction of allowed traffic
- **User Control:** Restrict by user identity
- **Behavior Control:** Control how services are used (e.g., filter emails)

Limitations:

- Cannot stop attacks that bypass it
- Cannot protect against internal threats
- Cannot protect against unauthorized Wi-Fi access

2 Virtual Private Networks (VPN)

Definition:

- A VPN uses **public networks (Internet)** to create a **private connection** between users or offices.
- Provides secure communication as if using dedicated lines.
- **Arabic:** شبكة خاصة افتراضية تستخدم الإنترنت لتوفير اتصال آمن كأنه خط خاص.

Types of VPN:

1. Remote Access VPN

- Connects a single user to a private network via Internet.
- Useful for home users or telecommuters.
- **Arabic:** يسمح لمستخدم واحد بالوصول الآمن إلى الشبكة الداخلية من أي مكان.

2. Site-to-Site VPN

- Connects networks of multiple offices.
- **Intranet VPN:** within same company
- **Extranet VPN:** between different companies
- **Arabic:** يربط الشبكات بين فروع الشركة أو شركات مختلفة بأمان.

VPN Protocols:

Protocol	Function	Notes
IPSec	Secure IP communication	Tunnel mode encrypts entire packet; transport mode encrypts payload only
L2TP	Encapsulates PPP frames	Often combined with IPSec for secure connection
PPTP	Creates point-to-point tunnel	Widely used for remote users; supports multiple protocols (IP, IPX, NetBEUI)
SSL/TLS	Browser-based VPN	Common for secure web access; HTTPS uses SSL/TLS
OpenVPN	Open-source VPN	Supports site-to-site and point-to-point
SSH	Secure Shell	Encrypted tunnel for data transfer

Tunneling Types:

- **Site-to-Site:** Usually uses GRE (Generic Routing Encapsulation)
- **Remote Access:** Usually uses PPP

VPN Advantages:

- Secure remote access
 - Cost-effective compared to leased lines
 - Scalable and flexible
-

3 Wireless Application Protocol (WAP)

Definition:

- Standard for **mobile wireless devices** to access information and services.
- Device and network independent.
- **Arabic:** معيار للوصول إلى الإنترنت والخدمات على الأجهزة المحمولة.

Challenges:

- Low bandwidth, high latency, unstable connections
- Limited CPU, memory, small screens on mobile devices

WAP Stack:

Applications (HTML/JS)

→ WAE (Wireless Application Environment)

→ WSP (Session Layer)

→ WTP (Transaction Layer)

→ WTLS (Security Layer)

→ WDP (Transport Layer)

→ Bearers (SMS, USSD, CDMA, etc.)

Key Protocols:

1. **WSP:** Session management, connection-oriented or connectionless
2. **WTP:** Transaction requests/responses, reliable transport
3. **WDP:** Maps higher-level protocols to wireless networks
4. **WTLS:** Security between device and WAP gateway (encryption, authentication, integrity)

WTLS Concepts:

- **Secure Connection:** Temporary transport connection associated with 1 session
- **Secure Session:** Association between client and server, created by handshake, defines cryptographic parameters

Handshake Protocol:

- Negotiates encryption algorithms, session keys, certificates
- Some messages are optional

End-to-End Security (WAP2):

- **TLS-based:** Encrypts data from device to server
- **IPSec-based:** Alternative for full network security

WAP Markup Language (WML):

- Similar to HTML but optimized for small screens
 - Uses **Decks** (pages) and **Cards** (interaction units)
-

4 Email Security

PGP (Pretty Good Privacy):

- Provides **confidentiality, authentication, compression, email compatibility, and segmentation.**
- Workflow:
 1. Hash message with SHA-1 → Digital Signature using sender private key
 2. Encrypt message with session key → Encrypt session key with recipient's public key
 3. Compress message (ZIP)
 4. Convert to ASCII (Radix-64) for email transport
- **Arabic:** تشفير وتأمين البريد مع ضغط وتقسيم الرسائل.

S/MIME:

- Industry standard for secure email
- Uses: SHA-1, DSS (signatures), Triple-DES/RC2 (encryption), RSA/DH (key exchange)

Email Protocols:

Protocol Function		Default Ports	Notes
SMTP	Send email	25 (non-secure), 2525 (alternative), 465 (secure)	Standard for sending mail
POP3	Receive email to local client	110 (non-secure), 995 (secure)	Downloads email, usually deletes from server

Protocol	Function	Default Ports	Notes
IMAP	Access email on server	143 (non-secure), 993 (secure)	Supports multiple clients simultaneously, better for mobile/multi-user

? **COA:** (الأصعب) معاك شفرة بس.

? **KPA:** (أصل + شفرة) معاك عينات قديمة.

? **CPA:** أنت بتجرب تشفير كلام من دماغك.

? **ACPA:** بتجرب تشفير كلام وتعدل تجربتك ذكياً.

? **MITM:** أنت في النص بتخطف المعلومات.

1. What are the two primary goals of cryptography?

- **Encryption:** Hiding messages so they cannot be read by anyone except the intended recipient.
- **Authentication & Integrity:** Ensuring the sender's identity is real and that the message has not been changed during transmission.

2. Explain the fundamental difference between symmetric and asymmetric encryption.

- **Symmetric Encryption:** Uses the **same key** for both locking (encrypting) and unlocking (decrypting) the data.
- **Asymmetric Encryption:** Uses a **pair of keys**: a Public Key (to encrypt) and a Private Key (to decrypt).

3. Describe how the Caesar Cipher works and its major weakness.

- **How it works:** It is a substitution technique where each letter in the text is replaced by another letter a fixed number of positions (usually 3) down the alphabet.
- **Weakness:** It has a very small "key space" (only 25 possible shifts), making it very easy to crack using a brute-force attack or frequency analysis.

4. What is the difference between a block cipher and a stream cipher? Give an example of each.

- **Block Cipher:** Encrypts data in fixed-sized chunks or "blocks" (e.g., 64 or 128 bits). *Example: AES.*
- **Stream Cipher:** Encrypts data one bit or one byte at a time. *Example: RC4.*

5. Why is key length so important in symmetric cryptography?

- Key length determines the strength of the algorithm. A longer key increases the number of possible combinations, making it much harder and more time-consuming for an attacker to guess the key through brute force.

6. What are the main advantages and disadvantages of symmetric-key cryptography?

- **Advantages:** It is very fast and uses less computing power.
- **Disadvantages:** It is difficult to securely share the secret key with the other party, and managing keys for many users is complicated.

7. What are the main advantages and disadvantages of asymmetric-key cryptography?

- **Advantages:** You don't need to share secret keys (public keys are open), and it allows for digital signatures.
- **Disadvantages:** It is much slower and more mathematically complex than symmetric encryption.

8. Explain the purpose of the Diffie-Hellman key exchange protocol.

- It allows two parties to safely create and share a secret key over a public, unsecure network without actually sending the key itself. This shared key can then be used for symmetric encryption.

9. How does a hash function differ from encryption?

- **Encryption** is two-way: you can encrypt and then decrypt back to the original text.
- **Hash functions** are one-way: you turn data into a fixed-length string, but you cannot turn that string back into the original data. It is used to check if data has been tampered with.

10. What is the purpose of an HMAC?

- HMAC (Keyed-Hash Message Authentication Code) is used to guarantee both the **integrity** of a message and its **authenticity** by using a secret key along with a hash function.

11. List and briefly describe three types of cryptanalysis attacks.

1. **Ciphertext-Only (COA):** The attacker only has the encrypted message and tries to find the key.
2. **Known-Plaintext (KPA):** The attacker has some pairs of original text and its encrypted version.
3. **Chosen-Plaintext (CPA):** The attacker chooses a specific text to be encrypted to see what the output looks like.

12. What is the difference between a firewall "whitelist" and "blacklist" approach?

- **Whitelist (Default-Deny):** Blocks everything and only allows what is specifically listed as safe. (More secure).
- **Blacklist (Default-Allow):** Allows everything and only blocks what is specifically listed as dangerous.

13. Describe the function of a packet-filtering firewall. What are its limitations?

- **Function:** It inspects each packet's header (IP addresses, ports, and protocols) against a set of rules.
- **Limitations:** it doesn't look at the actual data (payload) inside the packet and cannot track the "state" or context of a connection.

14. How does a stateful inspection firewall improve upon a basic packet filter?

- It keeps a "state table" to track active connections. It only allows incoming traffic if it is a response to a valid request that started from inside the network.

15. What is the primary role of a proxy (application) firewall?

- It acts as an intermediary (middleman). It breaks the direct connection between the sender and receiver, inspecting the data at the application layer before passing it on.

16. What specific threats does a Web Application Firewall (WAF) aim to prevent?

- It is designed to block attacks targeting web servers, such as **SQL Injection** and **Cross-Site Scripting (XSS)**.

17. What additional capabilities does a Next-Generation Firewall (NGFW) have?

- Unlike traditional firewalls, it includes **Application Awareness**, integrated **IPS**, and the ability to inspect encrypted traffic.

18. What is the purpose of a DMZ in network architecture?

- A DMZ (Demilitarized Zone) is a "buffer zone" that holds public-facing servers (like web or email). If an attacker hacks these servers, they are still isolated from the internal private network.

19. Compare and contrast Remote Access VPNs and Site-to-Site VPNs.

- **Remote Access:** Connects an individual user to the office network.
- **Site-to-Site:** Connects two entire networks together (like a branch office to the main headquarters).

20. What is the function of a tunneling protocol in a VPN?

- It "wraps" (encapsulates) private data packets inside public packets so they can travel securely across the Internet as if they were in a private tunnel.

21. What were the main constraints that led to the development of WAP?

- Mobile devices had **limited CPU power**, small screens, low memory, and were used on networks with **low bandwidth**.

22. What is the role of the WAP Gateway?

- It acts as a translator between mobile WAP protocols and standard Internet protocols

23. Describe the two main services provided by PGP.

- **Confidentiality:** Encrypting the email so only the recipient can read it.
- **Authentication:** Using digital signatures to prove who sent the email

24. What is the key difference between how POP3 and IMAP handle email?

- **POP3:** Downloads the email to your device and usually **deletes** it from the server.
- **IMAP: Syncs** the email with the server, allowing you to access the same messages from multiple devices.

25. How does Cipher Block Chaining (CBC) mode add security?

- It XORs each block of plain text with the previous block of encrypted text before encrypting it. This ensures that even if you encrypt the same word twice, the resulting code will look different each time.

26. Explain the concept of a "man-in-the-middle" attack.

- An attacker sits between two communicating parties, intercepts their messages or keys, and can read or modify them without either party knowing.

27. What is the relationship between WTLS in WAP and TLS on the Internet?

- WTLS is the wireless version of the TLS standard. It provides the same security (privacy and integrity) but is optimized for mobile devices and slow networks. (*Ref: Lecture 7, Page 33*)

28. Why might an organization choose to use a UTM appliance?

- Because it is an "all-in-one" device that combines a firewall, antivirus, VPN, and filtering into one box, making it easier and cheaper to manage.

29. What does "egress filtering" on a firewall help to prevent?

- It monitors and limits traffic **leaving** the network to prevent sensitive data from being stolen or to stop infected internal computers from communicating with hackers

30. How does public-key cryptography enable both encryption and digital signatures?

- **For Encryption:** You use the recipient's **Public Key** so only they can open it.
- **For Signatures:** You use your own **Private Key** to sign the message; since only you have that key, others can use your public key to verify it was definitely you.